GRC103 Risk Assessment and Management Techniques

Risk Treatment Strategies

Student Information	
Full Name	Khodani Netshifhefhe
Registration Number	C11/26/CGRCE/17580
Email Address	c11.cgrce2617580@icdfa.edu.ng
Submission Date	08 November 2026

Management summary

Treatment cut the four baseline risks (all High, scores 12 to 16) to two Low and two Medium, without interrupting the approved portal. Every result below comes from tests run on the two lab VMs.

- **Legacy endpoint removed (R1):** port 8080 went from open to closed; port 80 still returns HTTP 200.
- **Archive no longer published (R2):** the archive moved to a root-only folder; /archive/, the dummy file and / now return 403, /public/ returns 200.
- **Network access restricted (R3):** UFW allows only the approved Kali address (192.168.81.128) to port 80.
- **Recovery proven (R4):** a deleted portal file was restored from backup, the SHA-256 hash matched, and service returned in about 5 min 48 s.
- **Residual risk:** the backup is on the same host, the firewall is a single-source rule, and plain HTTP is accepted only temporarily (14 days, simulated approval).
- **Recommendation:** adopt options A + B + C for a first-year cost of $610 (hardening, managed backup, TLS). Option B's benefit is an illustrative assumption, not a measured result.
-

1. Lab environment

Item	Value
Ubuntu Server 24.04 LTS (server)	192.168.81.129, Nginx 1.24.0, Python 3.12.3, UFW 0.36.2
Kali Linux (client)	192.168.81.128
Network	Isolated VMware network; NAT used only to install packages, then disconnected [confirm]
Data	Fictional dummy files only; no real data

Timestamp note: Kali's clock reads 3 hours ahead of the server's UTC log time for the same request (Kali 19:24:44 vs Nginx 16:24:44 UTC), so its +01:00 label is not reliable. This report uses server UTC times as the reference and matches Kali evidence to them through the HTTP Date headers.

2. Baseline evidence and risk register

Baseline was collected from Kali at 18:57:20 Kali time (15:57:32 GMT on the server). Results matched the expected baseline:

- Nmap showed ports 80 and 8080 open (baseline-ports.txt).
- The root and /archive/ returned directory listings (HTTP 200), and /archive/dummy-records.txt returned DUMMY RECORD A001 - training only (baseline-web.txt, baseline-listing.txt, baseline-file.txt).
- Port 8080 returned Legacy training endpoint from Python SimpleHTTP/0.6 (baseline-legacy.txt). On Ubuntu, ss -lntp showed nginx on 0.0.0.0:80 and python3 on 0.0.0.0:8080, and grc-legacy was active.

Scoring: likelihood (L) 1 to 5 × impact (I) 1 to 5. Bands: 1-4 Low, 5-9 Medium, 10-16 High, 17-25 Critical. These are classroom thresholds, ordinal values, not money or probabilities.

ID	Asset	Threat event	Observed weakness	L	I	Score	Band	Evidence	Owner
R1	Legacy endpoint (port 8080)	Unauthorised access to an unneeded service	Unused service listening on 0.0.0.0:8080	4	3	12	High	baseline-ports.txt, baseline-legacy.txt	IT Operations Manager
R2	Archive directory (dummy records)	Information disclosure via web	Listing on, archive inside web root, file retrievable	4	4	16	High	baseline-listing.txt, baseline-file.txt	Information Security Officer
R3	Document server (port 80)	Unauthorised network access	No firewall restriction, any host can connect	4	3	12	High	baseline-ports.txt, UFW status output	Network/Systems Administrator
R4	Approved portal content	Loss by deletion or corruption	No backup or tested recovery	3	4	12	High	Step 10 evidence (none at baseline)	Service Owner

3. Avoidance: retire the legacy endpoint (Step 6)

Field	Entry

Proposed change	Retire the unused legacy endpoint on port 8080; keep the approved portal on port 80
Business impact	None: the endpoint is unused and holds no real data
Approval role	IT Operations Manager (**simulated approval**)
Test	Port scan and curl from Kali; systemctl is-active grc-legacy on Ubuntu
Rollback	sudo systemctl enable --now grc-legacy (final state: disabled)

Commands run: sudo systemctl disable --now grc-legacy, then systemctl is-active grc-legacy and ss -lntp. Kali results (avoidance-ports.txt, avoidance-legacy.txt): port 80 open, port 8080 closed, and curl failed with error 7 (could not connect). The later ss output shows no listener on 8080.

Why this is avoidance, not elimination: the retired workflow's exposure is gone because the service no longer exists to be attacked. The remaining Nginx portal still has other risks such as archive exposure, open network access, content loss, plain HTTP, which the later steps treat.

4. Archive hardening (Step 7)

The archive was moved to /srv/grc-private (permissions go-rwx), directory listing was set to autoindex off, and location /archive/ { deny all; } was added. nginx -t passed before reload.

Results from Kali and the Nginx log (16:12:58 UTC): /public/ 200, /archive/ 403, /archive/dummy-records.txt 403, / 403.

Why disabling listings alone is not enough: autoindex only hides the file index. A visitor who knows or guesses the file path (/archive/dummy-records.txt) would still download it. Moving the file out of the web root and denying the path removes the publication itself.

5. Firewall restriction (Step 8)

UFW was set to default deny incoming and default allow outgoing, with one rule: allow TCP port 80 from 192.168.81.128, logging on. ufw status showed 80/tcp ALLOW IN 192.168.81.128 as rule 1, and the firewall is active on startup.

From the approved Kali address, /public/ returned HTTP 200 (Nginx log 16:23:44 and 16:24:44 UTC).

Blocked-source test: [insert the second-address test from 192.168.81.11: the result, the timestamp, and the matching UFW BLOCK log entry. If you only saw a timeout and no log entry, write: timeout observed, firewall logs unverified. That is an unverified control, not a failed one.]

Observation: ss also showed SSH listening on port 22 (part of the base image, not this exercise). UFW's single allow rule shields it from the network, and the drift check below covers it.

6. Log correlation (Step 9)

From the approved address, Kali requested /public/ then /archive/ (step9-time.txt, 19:24:44 Kali time). The Nginx access log recorded GET /public/ 200 (25 bytes) and GET /archive/ 403 (162 bytes) at 16:24:44 UTC.

Nginx logs only requests that reach it: the allowed requests (200 and 403), including the deny-all decision made by Nginx itself. A request from a firewall-blocked source is dropped by the kernel firewall before it reaches port 80, so it should appear in the UFW kernel log and **not** in the Nginx log.

Test	Source	Service	Expected	Actual	Time (UTC)	Reference
T1	192.168.81.128	/ on port 80 (baseline)	Listing, 200	200, listing	15:57:32	baseline-web.txt, Nginx log
T2	192.168.81.128	/archive/ (baseline)	Listing, 200	200, listing	15:57:32	baseline-listing.txt
T3	192.168.81.128	/archive/dummy-records.txt (baseline)	200	200	15:57:32	baseline-file.txt
T4	192.168.81.128	Port 8080 (baseline)	200	200, Python SimpleHTTP	15:57:32	baseline-legacy.txt (not in Nginx log)
T5	192.168.81.128	Ports 80 and 8080 (after avoidance)	80 open, 8080 closed	80 open, 8080	about 16:03	avoidance-ports.txt,

				closed, curl error 7		avoidance-legacy.txt
T6	192.168.81.128	/public/	200	200	16:12:58	Nginx log
T7	192.168.81.128	/archive/	403	403	16:12:58	Nginx log
T8	192.168.81.128	/archive/dummy-records.txt	403	403	16:12:58	Nginx log
T9	192.168.81.128	/	403	403	16:12:58	Nginx log
T10	192.168.81.128	/public/ (UFW on)	200	200	16:23:44, 16:24:44	step9-public.txt, Nginx log
T11	192.168.81.128	/archive/ (UFW on)	403	403	16:24:44	step9-archive.txt, Nginx log
T12	192.168.81.11 (second address)	/public/	Timeout, no portal	[insert]	[insert]	[UFW BLOCK entry, or note logs unverified]

7. Backup and recovery (Step 10)

A protected backup (/srv/grc-backups, mode 700) was created with tar, and the SHA-256 of the original portal file was recorded:

e5b34d9b4fa6452b6b1d292b0ced654c99977f7ebece28a2731f633f53a50f72 /var/www/grc-lab/public/index.html

Recovery exercise start (recorded before deletion): **2026-11-10T16:49:38+00:00**. The file was deleted with sudo rm, then restored with tar -xzpf and checked with sha256sum -c.

Measure	Result

Failed service check after deletion	[attach screenshot: /public/ no longer returns the approved page]
Hash comparison after restore	[attach screenshot: portal-before.sha256: OK]
Restored service	HTTP 200, content Approved internal portal (Kali, step10-restore.txt, server Date 16:55:26 GMT)
Observed recovery time	16:55:26 minus 16:49:38 = 5 min 48 s (348 s), including manual typing and switching between VMs

Limitation: a backup on the same host protects against file deletion but not against complete host loss or compromise, because the backup is lost or altered together with the server.